

CHAPITRE 12 / 13 - Travaux Diriges

Continuite d'activite : ISO 22301, PCA et PRA

Enonce - Cas Banque Atlantis : simulation de panne totale du datacenter

Duree indicative : 30 a 45 minutes

A realiser individuellement ou en binome

Bareme sur 20 points

Contexte : Banque Atlantis

Banque Atlantis est une banque regionale fictive (1 200 salaries, 40 agences, une filiale assurance, une plateforme de banque en ligne et une application mobile de paiement). Sa RSSI, **Claire Dubois**, pilote depuis deux ans un programme de mise en conformite ISO/IEC 27001. Son DSI, **Marc Lefevre**, encadre une equipe de 60 personnes. Thomas Roussel, chef de projet cloud, est en charge des solutions d'hebergement externalisees de la banque.

L'incident du jour : incendie au datacenter principal

Ce vendredi, a 13h40, un incendie se declare dans le local technique du datacenter principal de Banque Atlantis, situe au siege. Les pompiers coupent l'alimentation electrique de l'ensemble de la salle par mesure de securite. **Le datacenter principal est totalement indisponible** pour une duree encore inconnue, estimee entre 24 et 72 heures par les services techniques. La direction generale declenche immediatement la cellule de crise et demande a Claire Dubois de coordonner l'analyse d'impact avant de decider des mesures de bascule a activer.

Les trois processus a analyser

- **Virement interbancaire** : traite en moyenne 45 000 virements par jour ouvre (salaires, prelevements, ordres clients) ; base sur une plateforme de compensation interbancaire reglementee ; toute suspension au-dela de quelques heures expose la banque a des penalites contractuelles et a une obligation de notification sous DORA.
- **Paieement par carte** : environ 60 000 transactions par carte bancaire par jour (paiements en magasin et en ligne) ; tres forte visibilite client immediate, une carte refusee au supermarche est visible et commentee en quelques minutes sur les reseaux sociaux.
- **Banque en ligne** : portail web et application mobile permettant aux clients de consulter leurs comptes, faire des virements simples et contacter un conseiller ; environ 25 000 connexions quotidiennes ; fonctionnalites redondantes avec les canaux physiques (agences, telephone) qui restent partiellement operationnels.

Elements complementaires disponibles

- Le site secondaire de Banque Atlantis, situe a 60 km du siege, dispose d'une infrastructure partiellement configuree pour les applications les plus critiques, mais necessite une intervention manuelle de quelques heures pour etre pleinement operationnel.
- Thomas Roussel a deja etudie une offre de reprise d'activite en mode DRaaS (Disaster Recovery as a Service) aupres d'un fournisseur cloud, mais le contrat n'a pas encore ete signe a ce jour.
- La derniere sauvegarde complete valide des bases de donnees date de la veille a 22h00 ; des sauvegardes incrementielles sont realisees toutes les 15 minutes sur le systeme de virement, toutes les heures sur les autres systemes.
- Aucun exercice de crise grandeur nature n'a ete realise depuis 3 ans chez Banque Atlantis ; un exercice sur table a eu lieu il y a 8 mois.

A CONSERVER

Ce cas reutilise le fil rouge Banque Atlantis introduit au chapitre 1 et enrichi au fil du module : conservez votre copie, elle pourra etre reprise en synthese au chapitre 13.

Exercice 1 - Realiser un mini-BIA sur les trois processus (6 points)

1. Pour chacun des trois processus (virement interbancaire, paiement par carte, banque en ligne), evaluez sa **criticite** (Vital / Majeur / Important / Mineur) en vous appuyant sur les elements de volume et de visibilite donnees dans le contexte. Justifiez chaque niveau retenu en une ou deux phrases.
2. Pour chaque processus, identifiez au moins une **consquence financiere** et une **consquence d'image ou reglementaire** d'une interruption prolongee au-dela de 24 heures.

Exercice 2 - Fixer des RTO et des RPO coherents (6 points)

Pour chacun des trois processus, proposez un **RTO** (delai maximal d'indisponibilite acceptable) et un **RPO** (perte de donnees maximale acceptable) cibles, exprimes en unites de temps precises, et justifiez chaque choix en vous appuyant sur la criticite determinee a l'exercice 1 et sur la grille de coherence vue en cours.

Processus	RTO cible (a completer)	RPO cible (a completer)	Justification (a completer)
Virement interbancaire			
Paiement par carte			
Banque en ligne			

Exercice 3 - Choisir une strategie de site de secours argumentee (5 points)

1. Pour chacun des trois processus, proposez un type de site de secours (froid, tiede ou chaud) et un mode de replication des donnees (synchrone ou asynchrone) coherents avec le RTO et le RPO fixes a l'exercice 2. Justifiez chaque choix.
2. Le site secondaire existant a 60 km necessite une intervention manuelle de quelques heures avant d'etre operationnel : pour quel(s) processus ce site suffit-il en l'etat, et pour le(s)quel(s) faudrait-il envisager une solution complementaire (par exemple le DRaaS etudie par Thomas Roussel) ? Justifiez.

Exercice 4 - Distinguer ce qui releve du PCA et du PRA (2 points)

1. Parmi les actions suivantes a mener dans les prochaines heures, indiquez pour chacune si elle releve principalement du PCA ou du PRA, en justifiant brievement : (a) informer les clients par SMS d'une possible instabilite du service de paiement ; (b) basculer techniquement les serveurs de virement vers le site secondaire ; (c) reloger temporairement les equipes du siege si l'incendie rendait aussi les locaux inaccessibles ; (d) restaurer la derniere sauvegarde valide des bases de donnees.

Exercice 5 - Tirer les enseignements pour la suite (1 point)

1. Le contexte indique qu'aucun exercice de crise grandeur nature n'a ete realise depuis 3 ans. En une ou deux phrases, expliquez en quoi cet element aurait pu aggraver la gestion reelle de cet incident, et proposez une action corrective immediate a l'issue de cette crise.

BAREME

Bareme indicatif sur 20 points : Exercice 1 = 6 pts, Exercice 2 = 6 pts, Exercice 3 = 5 pts, Exercice 4 = 2 pts, Exercice 5 = 1 pt. La coherence entre criticite, RTO/RPO et strategie de site de secours compte au moins autant que la valeur chiffrée exacte retenue.